

Security-/Threat-Model

SASD Desktop Secret Manager

Security-/Threat-Model

Arbeits- und Entscheidungsgrundlage für Sicherheitsgrenzen, Bedrohungen, Kontrollen und V1-Release-Gates

Metadatum	Wert
Dokumenttyp	Security-/Threat-Model
Projekt	SASD Desktop Secret Manager
Dokumentziel	Bedrohungen, Schutzgrenzen, Sicherheitsanforderungen, Kontrollen und Test-/Abnahmekriterien für die weitere Entwicklung festlegen.
Bezugsbasis	Überarbeitetes Lastenheft, Pflichtenheft, Architekturupdate, Roadmap, Featuremap, README und bisherige Projektchats.
Status	Arbeits- und Entscheidungsgrundlage; kein externes Security-Audit.
Stand	2026-05-18

Leitgedanke

Das Produkt soll Sicherheitsfunktionen ehrlich und überprüfbar umsetzen. Es schützt lokal gespeicherte Tresordateien und typische Fehlbedienungsrisiken, verspricht aber keinen vollständigen Schutz gegen ein bereits kompromittiertes Betriebssystem.

Inhaltsübersicht

- 1. Management Summary
- 2. Zweck, Methode und Lesart
- 3. Systemkontext und Schutzzumfang
- 4. Assets und Datenklassifizierung
- 5. Angreifer, Missbrauchsfälle und Annahmen
- 6. Trust Boundaries und Datenflüsse
- 7. Sicherheitsziele und Nicht-Ziele
- 8. Bedrohungskatalog und Risikobewertung
- 9. Sicherheitsanforderungen und Kontrollen
- 10. Spezielle Betrachtung HTTPS/TLS-Zertifikate
- 11. Import, Export, Backups und Recovery
- 12. Tests, Verifikation und Release-Gates
- 13. Offene Entscheidungen und ADR-Vorschläge
- 14. Roadmap-Einordnung
- 15. Referenzen

1. Management Summary

Der SASD Desktop Secret Manager ist eine lokale, offline-first nutzbare Windows-Anwendung zur Verwaltung klassischer und technischer Secrets. Aus Sicherheitssicht stehen vier Schutzbereiche im Mittelpunkt: verschlüsselte Tresordateien, sichere Bedienung entsperrter Secrets, robuste Dateiverarbeitung und kontrollierte Interoperabilität. Neu ausdrücklich zu betrachten ist die HTTPS/TLS-Zertifikatsverwaltung, weil private Schlüssel, PFX/P12-Dateien und Key-Passphrases dieselbe oder höhere Kritikalität wie Passwörter besitzen.

Die wichtigste Sicherheitsentscheidung lautet: Das interne .svault-Format bleibt führend, die Security-Schicht kapselt KDF, Verschlüsselung, Clipboard-Schutz, Passwortgenerator, Auto-Lock und Redaction-Regeln, und Interop-Funktionen dürfen keine stillen Datenverluste oder Klartext-Leaks erzeugen. V1 muss insbesondere Clipboard-Autoclear, Auto-Lock, Datenverlustschutz, Passwortgenerator, Zertifikatseintrag und .psafe3-Import kontrolliert schließen.

Ergebnis der Threat-Modellierung

Die Grundarchitektur muss nicht neu erfunden werden. Sie benötigt aber verbindliche Security-Gates für Clipboard, Auto-Lock, Logs, Import/Export, Zertifikatsfelder, Backups, KDF-Agilität und Release-Härtung.

2. Zweck, Methode und Lesart

Dieses Dokument ist kein formales Penetrationstest-Ergebnis und kein externes Security-Audit. Es ist ein projektinternes Threat Model, das die Anforderungen aus Lastenheft, Pflichtenheft, Architektur, Featuremap und Roadmap in prüfbare Sicherheitsentscheidungen überführt.

Methodisch orientiert sich das Dokument an einer STRIDE-nahen Betrachtung: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service und Elevation of Privilege werden auf den lokalen Desktop-Kontext übertragen. Zusätzlich werden Bedienfehler, Import-/Export-Risiken, Backup-/Restore-Risiken und Zertifikatsrisiken betrachtet. Für jede Bedrohung werden Gegenmaßnahmen, Versionszuordnung und Testbarkeit festgelegt.

Lesart

Dieses Dokument soll Entwickler nicht mit abstrakten Sicherheitsbegriffen überfrachten, sondern konkrete Entscheidungen liefern: Was ist geschützt, was ist nicht geschützt, welche Kontrollen sind Pflicht, und woran erkennen wir vor V1, dass die Sicherheitsbasis tragfähig ist?

3. Systemkontext und Schutzzumfang

Der Schutzzumfang betrifft V1 als lokalen Einzelbenutzer-Secret-Manager. Keine V1-Ziele sind Cloud-Synchronisation, Team-Sharing, Mobile-Clients, Browser-Autofill, vollautomatische PKI/ACME-Abläufe und Enterprise-PAM. Mehrere unabhängige Tresore sind dagegen ausdrücklich Teil des Kerns.

Geschützt werden sollen insbesondere Diebstahl oder Verlust von Tresordateien, neugierige Mitleser am Arbeitsplatz, unbeabsichtigte Offenlegung über UI/Clipboard/Logs, Datenverlust beim Speichern, Fehlbedienung, beschädigte Importdateien und unsichere Exporte. Nicht vollständig beherrschbar sind Malware, Keylogger, RAM-Auslese, kompromittierte Windows-Konten und manipulierte Installationsumgebungen.

Schutzgrenze

Ein lokaler Secret Manager kann den Verlust einer verschlüsselten Tresordatei abfedern. Er kann aber kein

kompromittiertes Betriebssystem zuverlässig reparieren. Diese Grenze muss im README, in der Benutzerkurzdoku und im Sicherheitsdokument sichtbar bleiben.

Komponente	Verantwortung	Sicherheitsrelevanz
WinForms UI	Tresor öffnen, Einträge anzeigen, Reveal/Copy, Dialoge, Warnungen.	Darf keine Kryptografie selbst implementieren und keine Secrets ungefragt anzeigen.
Application	Use Cases, Validierung, Suche, EntryMutation, Zertifikats-ViewModels.	Muss Secret-Klassifizierung durchreichen und Fehlbedienung abfangen.
Domain	Vault, Entry, Group, Tag, CustomField, EntryType.	Führt fachliche Secret-Kennzeichnung und strukturierte Zertifikatsfelder.
Security	KDF, Verschlüsselung, Passwortgenerator, Clipboard, Auto-Lock, Redaction.	Sicherheitskritischer Kern, muss testbar bleiben.
Storage	.svault, atomisches Schreiben, Backups, Fehlerbehandlung, Migration.	Schützt persistente Daten und verhindert Datenverlust.
Interop.PasswordSafe	Import, Mapping, Importbericht, später Export.	Fremddateien sind untrusted input.

4. Assets und Datenklassifizierung

Die Sicherheitslogik darf nicht nur an einzelnen UI-Schaltflächen hängen. Entscheidend ist eine stabile Klassifizierung der Daten. Ein Feld, das fachlich ein Secret ist, muss in UI, Suche, Copy-Aktion, Log, Importbericht, Export und Test denselben Schutzstatus behalten.

ID	Asset	Klasse	Owner	Schutzanforderung
A-01	Master-Passwort	C5 - höchst kritisch	Benutzer	Nie speichern, nie loggen, nur im Entsperrkontext verwenden.
A-02	Abgeleiteter Vault-Key	C5 - höchst kritisch	Security-Schicht	Nur im Speicher während entsperrter Sitzung; keine Persistenz.
A-03	.svault-Datei	C4 - verschlüsselte Secrets	Storage	Diebstahl muss durch KDF + AEAD abgedeckt werden; Integrität prüfen.
A-04	SecretEntry.Secret	C4 - Secret	Domain/Storage	Passwörter, Tokens, API-Secrets, PFX-Passwörter, Key-Passphrases.
A-05	CustomField mit IsSecret	C4 - Secret	Domain/Application	Geheime Zusatzfelder maskieren, Clipboard schützen, nicht loggen.
A-06	HTTPS/TLS Private Key / PFX/P12	C4/C5 - hochkritisches Secret	Domain/Storage	Besonders restriktiv behandeln; keine Vorschau oder Exporte ohne Warnung.
A-07	Nicht-geheime Zertifikatsmetadaten	C2/C3 - technisch sensibel	Domain/Application	Domain, SANs, Issuer, Fingerprint, ValidTo; suchbar, aber nicht unnötig veröffentlichen.
A-08	Gruppen, Tags, Titel, Notizen	C2/C3	Domain/Application	Können interne Struktur verraten; abhängig vom Inhalt vertraulich behandeln.
A-09	App-Konfiguration / MRU-Liste	C1/C2	UI/Infrastructure	Keine Secrets und keine Master-Passwörter speichern.
A-10	Logs und Fehlerberichte	C1/C2, niemals C4/C5	Security/UI	Redaction erzwingen; keine kompletten Connection Strings mit Passwort.
A-11	Backups	C4 - wie Primärdatei	Storage	Verschlüsselt, versioniert, kontrolliert wiederherstellbar.
A-12	Import-/Exportdateien	C4/C5 bei Klartext	Interop/UI	Gefährlichster

ID	Asset	Klasse	Owner	Schutzanforderung
				Migrationsmoment; Warnungen und sichere Abläufe notwendig.

4.1 Datenklassen

Klasse	Beispiele	Regel
C0 Öffentlich	README, Screenshots, nicht-sensitive Dokumentation.	Darf veröffentlicht werden, muss aber keine internen Secrets enthalten.
C1 Lokal nicht geheim	Fensterposition, UI-Theme, Sprache, nicht-sensitive Preferences.	Darf außerhalb des Tresors liegen; trotzdem keine unnötige Preisgabe.
C2 Technisch intern	Gruppennamen, Tags, Provider, Hostnamen, Projektnamen.	Nicht automatisch geheim, aber für SASD oder Kunden oft vertraulich.
C3 Sensible Metadaten	Interne Servernamen, Deployment-Ziele, Zertifikatsdomains, Kundenbezug.	Nicht wie Passwort behandeln, aber im Export/Log sparsam verwenden.
C4 Secrets	Passwörter, Tokens, API-Keys, Private Keys, PFX-Passwörter, TOTP-Seeds.	Immer maskieren, nur kontrolliert kopieren, niemals loggen, nie unverschlüsselt speichern.
C5 Schlüsselmaterial	Master-Passwort, abgeleiteter Vault-Key, Entschlüsselungskontext.	Höchste Schutzklasse; möglichst kurzlebig, keine Persistenz, keine Diagnoseausgabe.

5. Angreifer, Missbrauchsfälle und Annahmen

Das Threat Model betrachtet nicht nur böswillige Angreifer. Bei einem Secret Manager sind Benutzerfehler, falsche Exporte, Debug-Logs, zu lange gefüllte Zwischenablagen und falsche Schutzversprechen ebenso gefährlich wie klassische Angriffe.

ID	Akteur/Risiko	Fähigkeit	Relevanz
TA-01	Neugieriger lokaler Mitleser	Sieht Bildschirm oder Zwischenablage kurzzeitig.	Reveal/Copy, Auto-Lock, Maskierung.
TA-02	Finder/Dieb einer Tresordatei	Besitzt .svault oder Backup, aber nicht das Master-Passwort.	KDF, AEAD, starke Master-Passphrase.
TA-03	Benutzerfehler	Löscht, verschiebt, exportiert oder überschreibt versehentlich Daten.	Bestätigungen, Dirty-State, Backups, Importberichte.
TA-04	Malware/Keylogger auf Windows	Liest Tastatur, RAM, Clipboard oder Prozessspeicher.	Nicht vollständig beherrschbar; ehrliche Schutzgrenze.
TA-05	Manipulierte Importdatei	Fehlerhafte oder bösartige .psafe3-/CSV-Datei.	Parser-Härtung, Größenlimits, Fehlerbehandlung, keine Codeausführung.
TA-06	Supply-Chain-/Installer-Angreifer	Manipuliert Binärdateien oder Release-Paket.	Checksums, Signierung später, Integritätsprüfung als begrenzte Maßnahme.
TA-07	Künftiger Online-/Leak-Service-Risikoakteur	Entsteht erst bei optionalen Online-Funktionen.	Opt-in, Datenschutzprüfung, keine Secret-Übertragung.
TA-08	SASD-internes Offboarding-/Organisationsrisiko	Spätere Teamnutzung ohne Rollen/Offboarding.	Für V1 nicht im Scope; für Team/Cloud separat modellieren.

5.1 Grundannahmen

- Der Benutzer arbeitet auf einem grundsätzlich vertrauenswürdigen Windows-System.
- Die Anwendung läuft als normaler Benutzerprozess ohne Kernel-, HSM- oder Secure-Enclave-Schutz.
- Die Tresordatei kann in fremde Hände geraten; das Master-Passwort soll dann die entscheidende Barriere bleiben.
- Ein kompromittiertes Betriebssystem kann durch die Anwendung nur begrenzt abgefedert werden.
- V1 ist offline-first; spätere Online-Funktionen brauchen ein eigenes Datenschutz- und Threat-Model-Update.

6. Trust Boundaries und Datenflüsse

Trust Boundaries markieren Stellen, an denen Daten eine andere Vertrauenszone betreten: vom UI in die Security-Schicht, von der Anwendung ins Dateisystem, vom Detailbereich in die Windows-Zwischenablage oder von einer Fremddatei in das interne Modell.

ID	Boundary	Beispiele	Hauptgefahr
TB-01	Benutzer/UI	Eingabe von Master-Passwort, Secret-Reveal, Copy, Import/Export-Bestätigung.	Fehlbedienung und Shoulder Surfing.
TB-02	App-Prozess / Windows-Benutzerkonto	WinForms, .NET Runtime, Speicher, Dialoge.	Malware/RAM/Keylogger nur begrenzt beherrschbar.
TB-03	Dateisystem	.svault, .tmp, .bak, LocalAppData, MRU.	Diebstahl, Beschädigung, parallele Bearbeitung.
TB-04	Zwischenablage	Copy von Passwort, Token, Private Key, Fingerprint, URL.	Andere Programme können Clipboard lesen.
TB-05	Import-/Exportgrenze	.psafe3, CSV, spätere Fremdformate.	Malformed files, Mapping-Verlust, Klartextdateien.
TB-06	Backup-/Sync-Orte	Lokale Backups, externe Datenträger, Nextcloud/Syncthing später.	Verlust, Diebstahl, alte Schlüsselstände.
TB-07	Optionale Online-Dienste	Update, News, Leak-Prüfung, spätere ACME/PKI.	Datenschutz, Telemetrie, unbeabsichtigte Secret-Übertragung.

6.1 Datenflüsse

ID	Fluss	Daten	Sicherheitsregel
DF-01 Tresor anlegen	Benutzer -> UI -> Security/KDF -> Storage -> .svault	Master-Passwort, KDF-Parameter, leerer Vault	Starkes Passwort, versionierter Header, kein Logging.
DF-02 Tresor öffnen	.svault -> Storage -> Security -> Domain -> UI	Ciphertext, Salt, Nonce, Tag, Master-Passwort	Header prüfen, AEAD validieren, falsches Passwort klar melden.
DF-03 Eintrag bearbeiten	UI -> Application -> Domain -> Dirty-State	Entry, CustomFields, Tags, Zertifikatsfelder	Validierung, Secret-Maskierung, Änderung nachvollziehen.
DF-04 Secret kopieren	UI/Detail -> ClipboardProtectionService -> Windows Clipboard	Passwort, Token, Private Key, PFX-Passwort	Auto-Clear, Statusfeedback, keine Logs.
DF-05 Auto-Lock	Inaktivitätsdetektor -> Session/LockService -> UI	Entsperrter Vault-Kontext	Sichtbare Secrets leeren/maskieren, erneutes Master-Passwort verlangen.
DF-06 Speichern/Backup	Domain -> Storage -> tmp -> backup -> .svault	Serialisierte Vault-Nutzlast	Atomisch, verschlüsselte Backups, Fehler robust behandeln.
DF-07 .psafe3-Import	Importdatei -> Interop -> Mapping -> Importbericht -> Vault	Fremdformatdaten	Nicht still verlieren, keine Klartext-Leaks, Parser defensiv.
DF-08 Zertifikatseintrag	UI -> Application -> Domain/CustomFields -> Storage	CN/SAN/Issuer/Fingerprint/Private Key/PFX	Metadaten suchbar, Private-Key-Felder besonders geschützt.
DF-09 Klartext-Export später	Vault -> Export-Assistent -> Warnung -> Datei	CSV/JSON/Kompatibilitätsexport	Default nein, Warnung, Zielpfad, sichere Nachbearbeitung dokumentieren.

7. Sicherheitsziele und Nicht-Ziele

7.1 Sicherheitsziele

- Vertraulichkeit verschlüsselter Tresore auch bei Verlust der Datei.
- Integrität von Vault-Dateien durch authentifizierte Verschlüsselung und Formatprüfung.
- Kontrollierte Sichtbarkeit von Secrets in UI, Clipboard und Logs.

- Robuste Dateiverarbeitung ohne stille Datenverluste.
- Sichere, nachvollziehbare Import-/Export-Prozesse.
- Ehrliche Schutzgrenzen und keine versteckte Recovery-Backdoor.
- Zertifikatsdaten als eigener Secret-Kontext mit besonderer Behandlung privater Schlüssel.

7.2 Nicht-Ziele

- Kein Schutzversprechen gegen vollständig kompromittierte Systeme, Keylogger oder RAM-Auslese.
- Keine Cloud-, Team-, Mobile- oder Browser-Autofill-Sicherheit in V1.
- Keine automatische ACME-/PKI-/Deployment-Automation in V1.
- Keine virtuelle Tastatur als Kernfunktion.
- Keine 1:1-Unterordnung unter Password Safe, wenn dadurch das interne Modell unsicher oder unvollständig würde.

8. Bedrohungskatalog und Risikobewertung

Bewertung: H = hoher Schaden bzw. hohe Priorität, M = mittel, L = niedrig. Die Priorität richtet sich nach Schaden, Eintrittswahrscheinlichkeit und Nähe zur V1-Abnahme. Die Einschätzung ist bewusst pragmatisch und soll die Umsetzung steuern, nicht ein formales Audit ersetzen.

ID	Bedrohung	Impact	Likelihood	Priorität	Kontrollen	Version
T-001	Diebstahl einer .svault-Datei oder Backup-Datei	H	M	H	PBKDF2-SHA256 aktuell mit starken Parametern, AES-256-GCM, KDF-Parameter im Header, starke Master-Passphrase, verschlüsselte Backups.	V1
T-002	Schwaches Master-Passwort erleichtert Offline-Angriff	H	M	H	Passwortstärke-Warnung, Empfehlung langer Passphrase, optional spätere Blocklist/Policy; kein trügerisches Sicherheitsversprechen.	V1/V1.x
T-003	Manipulierte oder beschädigte Vault-Datei	H	M	M	AEAD-Tag, Header-/Versionsprüfung, klare Fehlermeldung, keine stille Teilrettung als Erfolg.	V1
T-004	Datenverlust durch Abbruch beim Speichern	H	M	M	Temporäre Datei, atomisches Ersetzen, Backup vor Überschreiben, Flush/Fehlerbehandlung.	V1
T-005	Secret bleibt zu lange in der Zwischenablage	H	H	H	Zentraler ClipboardProtection Service, Auto-Clear, Statusfeedback, manuelles Clear, Tests.	V1
T-006	Shoulder Surfing / neugieriger Blick auf UI	M	H	M	Secrets standardmäßig maskiert, Reveal explizit, Auto-Lock, Detailansicht nach Lock leeren.	V1
T-007	Secrets landen in Logs oder Fehlerdialogen	H	M	H	Redaction-Regeln, keine kompletten Connection Strings mit Passwort, Tests für Log-Ausgaben.	V1

ID	Bedrohung	Impact	Likelihood	Priorität	Kontrollen	Version
T-008	Lokale App-Einstellungen enthalten vertrauliche Inhalte	M	M	M	Nur nicht-geheime MRU/Preferences außerhalb des Vaults; AppData prüfen.	V1.x
T-009	Malware, Keylogger oder RAM-Auslese auf kompromittiertem System	H	M	H	Ehrliche Nicht-Ziel-Abgrenzung; Auto-Lock/Maskierung mindert nur Nebenrisiken.	Dokumentation
T-010	Manipulierte .psafe 3-Datei triggert Parserfehler oder Datenverlust	M	M	M	Defensiver Import, Größenlimits, klare Fehler, Importbericht, keine Codeausführung.	V1
T-011	CSV-/Klartextexport wird vergessen oder synchronisiert	H	M	H	Klartext-Export nicht V1; später Warnung, Bestätigung, sichere Löschhinweise.	V2
T-012	Private Keys/PFX-Passwörter bei Zertifikaten werden versehentlich offenbart	H	M	H	Eigene Secret-Klassifizierung, Maskierung, kein Log, kein Klartextindex, Clipboard-Schutz.	V1
T-013	Zertifikatsablauf wird übersehen	M	M	M	ValidTo prominent anzeigen; V1.x Warnschwellen und Ablaufübersicht.	V1.x
T-014	Silent Data Loss beim Import/Export wegen fremder Formate	M	M	M	Mapping-Bericht, Warnungen, nicht abbildbare Daten kennzeichnen.	V1/V1.x
T-015	Parallele Bearbeitung desselben Tresors überschreibt Änderungen	M	M	M	Datesperre/Lockfile oder konservative Zweitöffnung, Dirty-State und Konfliktmeldung.	V1
T-016	Unsichere Recovery wird zur Backdoor	H	L	H	Keine versteckte Recovery; späteres Recovery nur explizit, dokumentiert und optional.	V3
T-017	Schwacher Passwortgenerator erzeugt vorhersagbare Secrets	H	M	H	Kryptografischer Zufallszahlengenerator, Generatoroptionen testen, keine Math.Random-Nutzung.	V1
T-018	Manipulierte Programmdateien oder Release-Pakete	H	L/M	M	Checksums/Release-Prozess; spätere Signierung; Integritätsprüfung als begrenzte Zusatzmaßnahme.	V1.x
T-019	Online-Funktionen übertragen sensible Daten	H	L	H	Offline-first; Update/News/Leak nur opt-in, datensparsam, ohne Secret-Upload.	V2/V3
T-020	Falsche Bedienung löscht/verschiebt viele Einträge	M	M	M	Bestätigungen, Undo später, Backup, Statusfeedback.	V1/V2

9. Sicherheitsanforderungen und Kontrollen

Die folgenden Kontrollen sind als verbindliche Sicherheitsanforderungen zu behandeln. Sie sollen in Code, Tests, Dokumentation und Release-Prozess wiederzufinden sein.

ID	Kontrolle	Anforderung	Nachweis
S-001	Schutzgrenze ehrlich dokumentieren	Produkt behauptet nicht, Malware/Keylogger/RAM-Angriffe vollständig zu neutralisieren.	README, Benutzerkurzdoku, Security-Dokument.
S-002	KDF-Agilität	KDF-Parameter pro Vault speichern; spätere Argon2id-Migration ermöglichen, ohne alte Vaults still zu brechen.	Storage-/Security-Tests, Formatversion.
S-003	Authentifizierte Verschlüsselung	Vault-Nutzlast nur mit authentifizierter Verschlüsselung speichern; Manipulation muss auffallen.	Tamper-Tests mit geänderter Datei.
S-004	Keine Secrets außerhalb des Vaults	MRU, Preferences, Logs und temporäre Dateien dürfen keine Secrets enthalten.	Code-Review, Grep-/Unit-Tests, manuelle QA.
S-005	Zentrale Secret-Klassifizierung	Entry.Secret und CustomField.IsSecret steuern Maskierung, Copy-Verhalten, Logging und Suche.	Domain-/Application-Tests.
S-006	Clipboard-Schutz	Alle sensiblen Copy-Aktionen laufen über denselben Service mit Auto-Clear.	Unit- und manuelle UI-Tests.
S-007	Auto-Lock	Nach Inaktivität sperren, UI maskieren/leeren, erneutes Master-Passwort verlangen.	Manuelle Abnahme und Session-Tests.
S-008	Redaction-Regeln	Logs und Fehlermeldungen enthalten keine Secrets, Tokens, Private Keys oder PFX-Passwörter.	Negativtests mit Testsecrets.
S-009	Backup-Sicherheit	Backups bleiben verschlüsselt und gelten schutzfachlich wie Primärdateien.	Backup/Restore-Tests.
S-010	Import defensiv behandeln	Fremddateien nie vertrauen; Fehler klar melden; Mapping nicht still verlieren.	Interop-Tests mit beschädigten/ungewöhnlichen Dateien.
S-011	Export mit Warnung	Klartext-Export nur explizit, später mit Warnung und Nachbearbeitungshinweisen.	V2-Konzept/UX-Test.
S-012	Zertifikats-Private-Keys besonders schützen	PrivateKeyPem, PFX/P12, Passphrases und PFX-Passwörter sind hochkritische Secrets.	Zertifikats-UI- und Log-Tests.
S-013	Datenverlustschutz	Dirty-State, Bestätigungen und atomisches Schreiben verhindern stille Verluste.	E2E-Abnahme.
S-014	Release-Härtung	Vor V1 Security-Review auf Logs, Clipboard, Lock, Import, Backup und Zertifikate.	Release-Gate.

10. Spezielle Betrachtung HTTPS/TLS-Zertifikate

HTTPS/TLS-Zertifikate sind in V1 keine PKI-Plattform, sondern strukturierte Secret-Einträge. Die Anwendung soll Domain/CN, SANs, Issuer, Fingerprint, ValidTo und Deployment-Ziel zuverlässig erfassen und suchen können. Private Schlüssel, PFX/P12-Passwörter und Key-Passphrases sind Secrets höchster Kritikalität.

Zertifikatsregel

CertificatePem ist in der Regel öffentlicher Zertifikatstext. PrivateKeyPem, PFX/P12-Inhalte, PFX-Passwort und Key-Passphrase sind Secrets. Die UI muss diese Felder deutlich unterscheiden und darf private Schlüssel niemals in Listen, Logs oder ungeschützten Vorschauen anzeigen.

ID	Zertifikatsbedrohung	Gegenmaßnahme
C-T01	Private Key wird in Detailansicht oder Liste sichtbar	Key-Felder in eigener Gruppe, immer maskiert, keine Listen-Spalte.
C-T02	PFX-Passwort wird als normales Textfeld gespeichert	FieldKind Secret und IsSecret erzwingen; Template macht sensible Felder eindeutig.
C-T03	CertificatePem wird mit PrivateKeyPem verwechselt	Feldnamen und UI-Beschriftungen klar trennen; Warnung bei "BEGIN PRIVATE KEY" im Zertifikatstext.
C-T04	Ablaufdaten werden nicht gepflegt	ValidTo als sichtbares Datum; V1.x Ablaufwarnungen; Sortierung nach ValidTo.
C-T05	Zertifikatsdateien als Klartext-Anhänge später	Anhänge erst V2 mit Verschlüsselung, Typprüfung und Größenlimits.
C-T06	ACME-/PKI-Automation gefährdet Systeme	Nicht V1; separates Betriebskonzept mit Rollen, Logging, Rollback und Zugriffsschutz.

11. Import, Export, Backups und Recovery

Import und Export sind Sicherheitsgrenzen. Der .psafe3-Import gehört zu V1, darf aber keine stillen Datenverluste erzeugen. Klartext-Exporte gehören nicht in V1 und müssen später mit Warnung, Bestätigung, Nachbearbeitungshinweisen und möglichst klarer Lösch-/Aufräumlogik umgesetzt werden. Backups müssen denselben Schutz wie die Primärdatei besitzen. Recovery darf nie eine versteckte Backdoor werden.

Bereich	V1-Regel	Spätere Regel
Password-Safe-Import	Reader/Mapper/Importbericht; defensiver Umgang mit Fremddateien.	Export nur mit Kompatibilitätsbericht und Verlusthinweisen.
CSV-/Klartextexport	Nicht Bestandteil der V1-Abnahme.	Nur explizit, gewarnt, dokumentiert und mit Aufräumhinweisen.
Backups	Verschlüsselte Backup-Dateien, keine Klartext-Sicherungen.	Restore-Assistent und zusätzliche Backup-Orte.
Recovery	Keine Hintertür, kein Entwickler-Notzugang.	Nur offizielles, dokumentiertes Recovery-Konzept ohne Backdoor.
Zertifikatsdateien	Keine erzwungenen Binäranhänge in V1.	V2: verschlüsselte Anhänge mit Typ-/Größenprüfung.

12. Tests, Verifikation und Release-Gates

Sicherheit muss überprüfbar sein. Für V1 reicht es nicht, Sicherheitsfeatures im README zu nennen. Sie müssen durch Unit-Tests, Integrationstests und manuelle QA mit reproduzierbaren Schritten nachgewiesen werden.

ID	Test	Erwartetes Ergebnis
ST-001	Wrong-password-Test	Öffnen mit falschem Master-Passwort liefert sauberen Fehler, keine Teilentschlüsselung.
ST-002	Tamper-Test	Geänderte Bytes in Ciphertext/Header werden erkannt; kein Vault wird als gültig akzeptiert.
ST-003	Truncated-file-Test	Abgeschnittene Datei wird erkannt und verständlich gemeldet.
ST-004	Atomic-save-Test	Simulierter Schreibabbruch beschädigt vorhandenen Tresor nicht.
ST-005	Backup-restore-Test	Backup lässt sich nachvollziehbar öffnen, wenn Primärdatei beschädigt ist.
ST-006	Clipboard-autoclear-Test	Sensible Werte werden kopiert und nach Zeit X entfernt; nicht-sensitive Copy-Aktionen bleiben korrekt.

ID	Test	Erwartetes Ergebnis
ST-007	Lock-Test	Nach Auto-Lock sind Detailfelder maskiert/geleert; Entsperren verlangt Master-Passwort.
ST-008	Log-redaction-Test	Testsecrets, Tokens, Private Keys und PFX-Passwörter erscheinen nicht in Logs.
ST-009	Certificate-secret-Test	PrivateKeyPem, PFX-Passwort und Passphrase sind maskiert, nicht in Suchtreffern offen sichtbar.
ST-010	Certificate-search-Test	Domain, SANs, Issuer, Fingerprint und DeploymentTarget werden gefunden.
ST-011	Import-malformed-Test	Beschädigte .psafe3-Dateien führen nicht zu Absturz oder Datenverlust.
ST-012	Import-report-Test	Nicht abbildbare Felder werden im Bericht sichtbar, nicht still verworfen.
ST-013	Generator-randomness-smoke-Test	Generator verwendet kryptografischen RNG; keine deterministischen Folgen zwischen Starts.
ST-014	Dirty-state-Test	Alle Eintrags-, Gruppen- und Zertifikatsänderungen setzen Dirty-State korrekt.
ST-015	Export-warning-Test	Späterer Klartext-Export erfordert ausdrückliche Bestätigung und erzeugt Warnhinweise.

12.1 V1-Release-Gates

- Keine bekannten High-Priority-Threats ohne dokumentierte Gegenmaßnahme.
- Clipboard-Autoclear und Auto-Lock sind implementiert, getestet und manuell geprüft.
- Keine Secrets in Logs, Fehlerdialogen, AppData-Preferences oder temporären Klartextdateien.
- .svault-Fehlerfälle, falsche Passwörter, beschädigte Dateien und Backups sind getestet.
- Zertifikatseinträge behandeln Private-Key-/PFX-Felder als Secrets.
- Importbericht für .psafe3 zeigt nicht abbildbare Inhalte sichtbar an.
- README und Benutzerkurzdoku nennen Schutzgrenzen und Nicht-Produktivitätsstatus korrekt.

13. Offene Entscheidungen und ADR-Vorschläge

Die folgenden Entscheidungen sollten nicht nur im Chat bleiben, sondern als kurze ADRs im Repository dokumentiert werden. Dadurch bleiben Sicherheitsentscheidungen später nachvollziehbar.

ADR	Thema	Zu klärende Entscheidung
ADR-S-001	KDF-Strategie und Migration	Aktueller PBKDF2-Profilzustand, mögliche Argon2id-Einführung, Migrationspfad, Mindestparameter.
ADR-S-002	Secret-Klassifizierung im Domain-Modell	Welche Feldtypen geheim sind und wie UI, Suche, Logs und Export daran gebunden werden.
ADR-S-003	ClipboardProtectionService	Zentraler Dienst, Autoclear-Zeit, Statusfeedback, Grenzen gegenüber Malware.
ADR-S-004	Auto-Lock und Session-Modell	Was beim Lock passiert, welche Daten im Speicher bleiben dürfen, wie Entsperren abläuft.
ADR-S-005	HTTPS/TLS-Zertifikatsmodell	Felder, Key-Behandlung, Datei-Anhänge erst später, keine V1-PKI-Automation.
ADR-S-006	Import/Export-Sicherheitsregeln	Warnungen, Importbericht, CSV-Verbot in V1, sichere Migrationshinweise.
ADR-S-007	Recovery ohne Backdoor	Zulässige spätere Recovery-Mechanismen und ausdrücklich ausgeschlossene Hintertüren.

ADR	Thema	Zu klärende Entscheidung
ADR-S-008	Release-Integrität	Checksums, Signierung, Manifestprüfung und Grenzen von Selbst-Hashing.

14. Roadmap-Einordnung

Version	Sicherheitspriorität	Inhalt
V1.0	Muss	Clipboard-Schutz, Auto-Lock, Passwortgenerator, Datenverlustschutz, .psafe3-Import, Zertifikatseintrag, Security-Review vor Release.
V1.x	Soll	Master-Passwort ändern, Restore-Komfort, Zertifikatsablauf-Warnungen, Integritäts-/Release-Prüfungen, bessere Konfliktbehandlung.
V2	Geplant	Verschlüsselte Anhänge, Zertifikatsdateien, TOTP, Historie, Cross-Vault, optionale Online-Funktionen mit Datenschutzkonzept.
V3/später	Nur mit separatem Konzept	Recovery ohne Backdoor, ACME-/PKI-Automation, Team/Cloud/Mobile, Browser-Import, Passkeys/WebAuthn.

Nächster sinnvoller Entwicklungsschwerpunkt

Vor neuen Komfortfunktionen sollten ClipboardProtectionService, Auto-Lock/LockService, Passwortgenerator, Dirty-State/Datenverlustschutz und der Zertifikatseintrag sauber implementiert und getestet werden. Genau diese Punkte schließen die wichtigste V1-Sicherheitslücke.

15. Referenzen

Interne Bezugsdokumente: überarbeitetes Lastenheft, überarbeitetes Pflichtenheft, Architekturprüfung/Architekturdokument, Roadmap, Featuremap und README des SASD Desktop Secret Managers.

Externe Orientierung: OWASP Threat Modeling Cheat Sheet, OWASP Secrets Management Cheat Sheet, OWASP Cryptographic Storage Cheat Sheet, OWASP Password Storage Cheat Sheet und NIST SP 800-63B. Diese Quellen ersetzen keine projektspezifische Prüfung, helfen aber bei Strukturierung, Kryptografie-, Secret-Management- und Passwort-Entscheidungen.